

Acme Corp - IT Security & Compliance Policy v2.1

1. Password Policy

All passwords must be a minimum of 12 characters and include at least one uppercase letter, one lowercase letter, one digit, and one special character. Passwords must be changed every 90 days. Password reuse (last 10 passwords) is prohibited. Multi-Factor Authentication (MFA) is mandatory for all accounts with access to production systems or sensitive data. Password managers are approved and encouraged; storing passwords in plaintext is a policy violation.

2. Data Classification

Public: Marketing materials, press releases - no restrictions. Internal: General business documents - accessible to all employees, not for external sharing. Confidential: Financial records, HR data, customer PII - role-based access only. Restricted: Source code, encryption keys, security configs - minimum-privilege access, audit-logged. All data must be labelled at creation. Misclassification incidents must be reported within 24 hours.

3. Incident Response Procedure

P1 (Critical): System-wide outage or data breach - respond within 15 minutes, escalate to CTO + CEO. P2 (High): Service degradation or security anomaly - respond within 1 hour, notify IT Manager. P3 (Medium): Non-critical bug or minor unauthorised access attempt - resolve within 24 hours. P4 (Low): Cosmetic issues, informational alerts - resolve within 5 business days. All incidents must be logged in the incident tracker (Jira project: ITSEC) within 30 minutes of detection.

4. Remote Access & VPN

All remote access to internal systems requires an active VPN connection (WireGuard on port 51820). VPN split-tunnelling is disabled; all traffic routes through the corporate gateway. Personal devices must pass endpoint compliance checks (OS patch level, AV active, disk encrypted). VPN session timeout: 8 hours of inactivity. USB storage devices are blocked on all corporate endpoints by MDM policy.

5. Audit & Compliance

Quarterly security audits are conducted by the IT Operations team with external pen-tests annually. Access logs for privileged accounts are retained for 12 months and reviewed monthly. The company is SOC 2 Type II and ISO 27001 certified. GDPR compliance: Data Subject Access Requests (DSARs) must be fulfilled within 30 days. Next external audit: March 2025 (scheduled with SecureAudit Inc.).